Praetor

The control plane for regulated AI agent wallets.

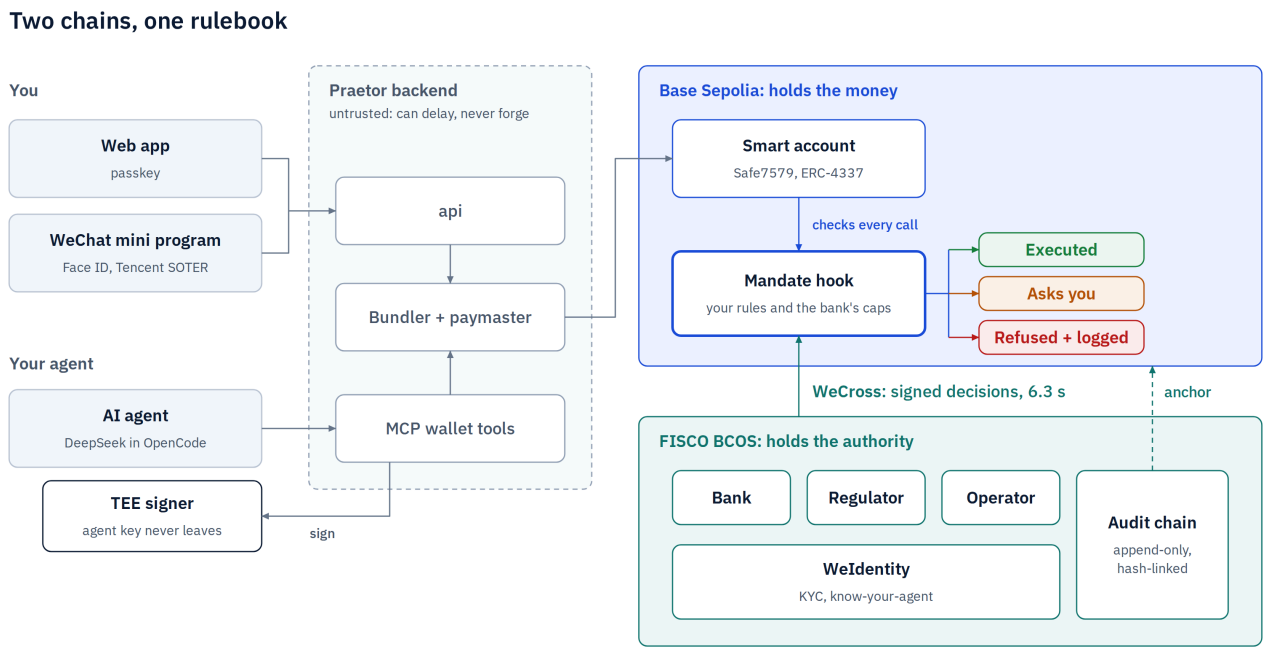
> **Self-driving money. The regulator holds the brakes.**

An AI agent operates an ERC-4337 smart account on **Base Sepolia** under an on-chain mandate. The authority over it (identity, compliance, governance, audit) sits with a **bank, a regulator and an operator** on a **FISCO BCOS** consortium, built with WeBank's open-source stack: **FISCO BCOS, WeIdentity and WeCross**. Every action of the agent is checked on-chain, bound to a verified identity, and governable by the consortium.

FinTechathon 2026 (Shenzhen, WeBank x Tsinghua PBCSF), International Track, Topic F "Agent Wallet". 中文: README.zh-CN.md.

Try it	**https://app.praetorwallet.com** (Base Sepolia, testnet only). Anyone can onboard at `/start` with a passkey; 1 USDC on chain stands for 100 in the story, and demo funds are small, on request from the team. Not open to visitors, by design: the consortium console (enrolled staff devices) and WeChat (testers of the mini program's test account); the one-click sandbox runs on a local fork (`make up`).
On-chain evidence	EVIDENCE-SERVER.md: the public server, its two TEEs on Phala Cloud and a WeChat Face ID approval on Base Sepolia. EVIDENCE.md: the evidence run of 2026-10-18, 10 flows, 21 BaseScan links, executed and refused.
Demo video	[VIDEO_URL]
Deck	[DECK_URL]
Docs	Architecture, security self-assessment, specification, deployment, 中文

Architecture: two chains, one rulebook



- **Base Sepolia holds the money.** Each user's Safe7579 account has one ERC-7579 hook, `MandateHook`, which every execution passes: executed, asks the owner, or refused with a logged reason.
- **FISCO BCOS holds the authority.** The bank, the regulator and the operator run member services on a four-node FISCO BCOS 3.17.1 chain: identity, compliance lists, the agent's status, the audit log.
- **WeCross carries the decisions.** A consortium decision is an EIP-712 message that members sign on FISCO; the WeCross router delivers it to Base, and a relayer delivers whatever WeCross has not applied within 120 s.
- **The hook re-verifies every signature** (distinct members, threshold, nonce, deadline). The backend, the model, the bundler, WeCross and the relayer are untrusted: they can delay a decision, never forge one. The 6.3 s in the picture (a freeze from FISCO to Base) was measured on the local fork.

What Praetor provides

Capability	What it does	Where
Smart agent wallet	Safe7579 (ERC-4337) account per user; the owner holds up to four passkeys; the agent key lives in a TEE (Phala Cloud, Intel TDX)	`contracts/base`, `services/agent-signer`, `services/bundler`
Mandate hook	Applies the owner's rules and the bank's caps, the stricter wins; default deny; every action falls in a tier, T0 to T4 (below)	`contracts/base/src/MandateHook.sol`, `src/hook/`
Identity (KYC)	The bank, a WeIdentity issuer, issues a `PersonKYC` credential to the user's WeID; personal data stays sealed in the bank	`services/bank`, `services/identity`
Know your agent (KYA)	Agent WeID; an `AgentMandate` signed by the user, then countersigned by the bank; the bank checks the TEE quote and sends Base a KYA with the TEE measurement	`services/bank`, `MandateRegistry.sol`

Capability	What it does	Where
Selective disclosure	EUDI wallet path (OpenID4VP, SD-JWT: birthdate and country only), unit-tested on fixtures; WeIdentity selective disclosure built and integration-tested, not used in the demo flows	`services/bank/src/eudiw.ts`, `test/integration/identity.test.ts`
Compliance	Sanctions, payout jurisdictions, approved assets and counterparties, bank caps per risk profile, set on FISCO and enforced by the hook; ERC-3643 `IdentityRegistry` and `Compliance` gate the tokenized metals	`contracts/fisco/src`, `contracts/base/src/tokens`
Consortium governance	1 of 3 tightens, 2 of 3 loosen, the bank alone for caps and KYA; nonces allocated on FISCO; operator silent for 15 min (production), the agent loses its autonomy	`contracts/fisco/src/Board.sol`, `services/bank`, `regulator`, `operator`
Cross-chain transport	WeCross router 1.4.0 with Praetor's EVM stub for Base; holds transport keys only; the bridge-relayer is the watchdog	`wecross/evm-stub`, `services/bridge-relayer`
Asset management	USDC, tokenized gold (tXAU) and silver (tXAG) in bands; the agent rebalances against a treasury desk at Pyth prices on Base Sepolia	`TreasuryDesk.sol`, `PriceOracle.sol`, `services/scheduler`, `oracle-feeder`
Payments and approvals	Agent payments to known payees under the auto cap; the owner approves the exact call by passkey, or Face ID in WeChat (SOTER, checked by an attester in a TEE)	`services/mcp`, `services/api`, `services/soter-attester`
Standing orders and payouts	Recurring bills held on-chain by the account's executor; paid through an escrow rail by a payout partner over Alipay+ or WeChat Pay (mocks)	`StandingOrders.sol`, `PayoutRail.sol`, `services/payout-partner`
Channels	Web app (PWA, EN and 中文), WeChat mini program, consortium console, MCP over OAuth 2.1 for outside agents	`apps/web`, `apps/miniprogram`, `services/mcp`
Audit	Hash-chained log on FISCO, anchored on Base by two members, verified from three sources; ISO 20022 camt.053 export	`services/operator`, `AuditLog.sol`, `Anchor.sol`
Agent runtime	Real model (DeepSeek through OpenCode); built-in tools denied; it reaches money only through Praetor's ten MCP tools	`services/agent-runner`, `services/mcp`
Key rotation and recovery	Stop or rotate the agent key; add devices; every passkey lost: bank re-KYC, then a 48 h delay that any passkey still held can cancel	`services/api`, `services/bank`, `MandateHook.sol`

Who may do what, enforced by the hook:

Tier	Who	Example
T0 Never	nobody: the hook refuses	over the bank's caps, sanctioned payee, hidden call, while frozen
T1 Autonomous	the agent alone	pay a known payee under the auto cap, rebalance inside the bands, a due standing order
T2 Human	the owner: passkey or SOTER	unknown payee, over the auto cap or a budget
T3 Owner + bank	the owner and the bank (the owner alone to make things stricter)	change the mandate, standing orders, the agent key
T4 Consortium	1 of 3 to tighten, 2 of 3 to loosen, the bank for caps and KYA	freeze, sanctions, assets, heartbeat

Flows

Every flow is an e2e test (`test/e2e`) and passes through the api and through the web app (Playwright) on fresh local forks. The Base Sepolia column links the transactions.

Flow	What happens	On Base Sepolia
F1 Onboarding	Passkey, smart account, KYC at the bank, agent key in the TEE, AgentMandate, KYA	run, server
F2 Link WeChat	Binds a WeChat SOTER key to the account (passkey and bank)	server
F3 Mandate	The owner sets the rules; the bank checks them on FISCO and co-signs	run, server
F4 Rebalancing	A demo price shock wakes the agent, which sells tXAU back into its band alone (T1)	local fork only
F5 Agent payment	A known payee paid alone (T1); a prompt-injected payment to a sanctioned address refused on-chain (SANCTIONED)	T1, SANCTIONED
F6 Human approval	A new payee refused (UNKNOWN_PAYEE); the owner approves that exact call; it executes once	passkey, WeChat SOTER
F7 Standing order	Rent (owner + bank) paid through the payout rail and the Alipay+ mock	run
F8 Audit	Head anchored on Base by two members, verified, camt.053	run
F9 Governance	Regulator freeze with one signature through WeCross, next payment refused FROZEN, loosening needs two; heartbeat, sanctions, assets, jurisdictions, caps	freeze and loosen; the rest on the local fork
F10 Rotation and recovery	Stop and rotate the agent key; owner recovery with the 48 h delay	local fork only (48 h time warp)

"run" is the evidence run of 2026-10-18 on the M16 deployment; "server" is the public server on its own deployment of 2026-10-19. They are two different Base Sepolia deployments.

Security

- **19 invariants**, I1 to I19 (spec/01-system.md), each mapped to the tests that prove it in the self-assessment, with 34 known risks stated.
- **Red team: 100 attack runs, 0 executed**, all on the local fork (2026-10-19): 85 scripted, 3 on shared state, 12 with the real model (3 blocked by the stack, 9 declined by the model; their scripted twins show the stack blocks the same attacks). "Executed" is judged from on-chain state, never from what the model said. Held-out cases not run yet. redteam.md
- **Contracts**: 235 Foundry unit, fuzz and invariant tests plus 13 fork tests on the real Safe7579; `MandateHook.sol` line coverage 99.52 %. Slither on Praetor's Base code: High 0, Medium 27, all explained (slither.md).
- **No personal data on Base (I19)**: `make i19-scan` found none on the M16 deployment nor on the local fork after the red team.
- **TEEs**: both CVMs on Phala Cloud with their compose hashes on the bank's allowlists; two items stay open (TLS ends at Phala's gateway, the debug bit is left to Phala's verifier): tee-checklist.md.

Run it

Prerequisites: Linux x86_64 (tested on Ubuntu 24.04), Docker with Compose v2, Node 22 with pnpm 10.29.1, Foundry 1.7.1, 16 GB of RAM recommended. Java runs only inside pinned images.

```
git clone --recurse-submodules <repository> praetor && cd praetor
make setup        # commit-msg hook + pnpm install --frozen-lockfile
pnpm keys         # fills every missing key and secret into .env (mode 600); prints public addresses only
make up           # anvil fork of Base Sepolia, 4 FISCO nodes, WeIdentity, WeCross, TEE simulator,
                  # member services, agent, mocks; deploys the contracts; builds the web app
pnpm seed         # optional: the demo persona Lin, onboarded and funded
make test         # guards, gitleaks, type-check, every unit test, Foundry
make test-int     # one integration test per link of the architecture (needs make up)
make e2e          # flows F1 to F10 through the api and the web app, then the 48 h recovery (needs make up)
```

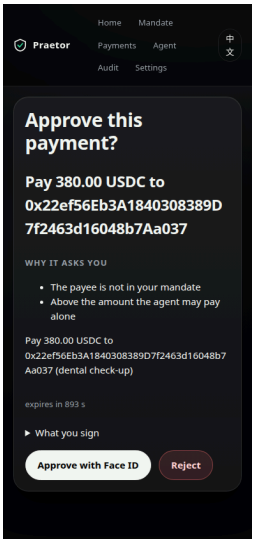
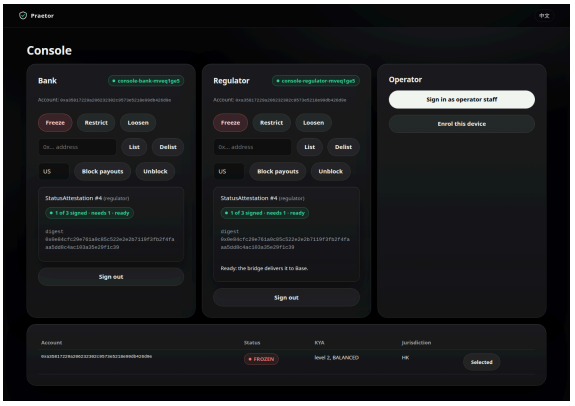
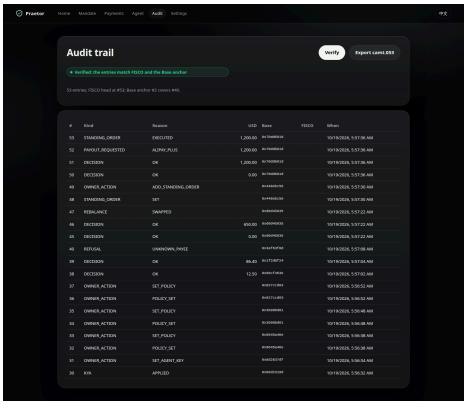
Open **https://praetor.localhost** (Caddy's internal CA: accept the warning, or trust `/data/caddy/pki/authorities/local/root.crt` from the `caddy` container). The one-click sandbox is at `/sandbox` on the fork. More targets: `make help`. Server and Phala Cloud deployment: docs/DEPLOY.md.

Status

- **Built and tested on the local fork**: every capability above (TEEs on the dstack simulator), milestones M0 to M18 (PROGRESS.md).
- **Live on Base Sepolia (2026-10-18)**: the evidence run, with real Pyth prices, the real model and WeCross as the transport (EVIDENCE.md).
- **Public server (2026-10-20)**: https://app.praetorwallet.com, Google Cloud in Hong Kong, its own Base deployment (MandateHook `0x6411cc907Ace53F1Bdf8607a85991d3b38E79a5f`) and its own FISCO consortium.
- **TEEs on Phala Cloud**: agent-signer and soter-attester in Intel TDX CVMs; the bank verified the attester's quote and activated it on Base. The dstack simulator runs only locally.
- **WeChat on an iPhone**: on the server, a refused payment approved with Face ID (SOTER) and executed once; on the local fork, replay refused, freeze, unlink, Chinese UI.
- **Production rehearsal** (on the fork): `make rehearsal` with `compose.prod.yml`, smoke 16/16 and the five production refusals.
- **Guomi (SM) profile**: smoke recorded in SMOKE.md.
- **Labelled mocks**: the KYC vendor, the payout partner, Alipay+ and WeChat Pay; the sandbox is an interim stand-in.
- **Still to come**: WeChat Official Account messages, an EUDI scan with a real wallet, the demo video, the Android fingerprint, web push on a phone, the pentest, the held-out red-team cases.

Document	What it covers
ARCHITECTURE.md	The system, core algorithms, security design, deployment
SELF_ASSESSMENT.md, security/	Tiers, invariants and their tests, threat model, known risks, tool results
EVIDENCE-SERVER.md, EVIDENCE.md	Transactions on Base Sepolia, executed and refused
DEPLOY.md, MANUAL.md, TESTER.md	Deployment, guided acceptance steps, phone testing
spec/, DECISIONS.md, PREEXISTING.md	The build specification, decisions taken since, reused code
中文	README.zh-CN.md, docs/zh-CN/

Screens

The owner approves the exact call	One regulator signature freezes	The audit chain, verified
		

Team and licence

Alexandre Huou (EPFL), Stan Stelcher (HEIG-VD).

Copyright © 2026 the Praetor team. All rights reserved. Source made available for evaluation by FinTechathon 2026 organisers and judges (LICENSE). Third-party components keep their own licences: NOTICE, THIRD_PARTY_LICENSES.md.